AI Act

Artificial Intelligence Act — Governance, Risk, Controls, and Implementation Template

Joao Luiz D'Andrea

Table of contents

1 Executive Summary **3**

2 Overview **4**
2.1 Purpose . . . 4
2.2 Objectives . . . 4
2.3 Scope . . . 4
2.3.1 In scope . . . 4
2.3.2 Out of scope . . . 4
2.4 Intended Audience . . . 5

3 Regulatory Foundation **5**
3.1 Background . . . 5
3.2 Regulatory Objectives . . . 5
3.3 Risk-Based Model . . . 5
3.4 Applicability and Entity Context . . . 6
3.4.1 Operator role table . . . 6

4 Governance Model **6**
4.1 Governance Objectives . . . 6
4.2 Governance Structure . . . 7
4.2.1 Example governance bodies . . . 7
4.3 Three Lines Model . . . 7
4.3.1 First line . . . 7
4.3.2 Second line . . . 7
4.3.3 Third line . . . 8

5 Roles and Responsibilities **8**
5.1 Key Roles . . . 8

5.2 RACI Matrix 8

6 Policy Framework **10**
6.1 Core Policies 10
6.2 Standards and Procedures 10

7 Core Processes **11**
7.1 AI Use Case Intake and Classification 11
7.2 Prohibited Practices Control 11
7.3 High-Risk AI Lifecycle Management 11
7.4 Transparency Management 12
7.5 General-Purpose AI Model Governance 12
7.6 Data Governance and Human Oversight 13
7.7 Incident and Issue Management 13
7.8 AI Literacy and Awareness 13

8 Control Framework **14**
8.1 Control Domains 14
8.1.1 Example control domains 14
8.2 Sample Control Catalogue 14

9 Artefacts and Evidence **15**
9.1 Required Artefacts 15
9.2 Evidence Model 16

10 Architecture and Technology Implications **16**
10.1 AI Governance by Design 16
10.2 Technology and Model Landscape View 16
10.3 Dependency and Data Flow Mapping 17

11 Risk Management **17**
11.1 AI Risk Model 17
11.2 Example Risk Categories 17
11.3 Risk Register Template 17

12 Metrics and Reporting **18**
12.1 Key Metrics 18
12.2 Dashboard Structure 18

13 Audit and Assurance **18**
13.1 Assurance Model 18
13.2 Testing Themes 19

14 Implementation Roadmap **19**
14.1 Maturity Phases . . . 19
14.1.1 Phase 1: Foundation . . . 19
14.1.2 Phase 2: Control Design . . . 19
14.1.3 Phase 3: Integration . . . 20
14.1.4 Phase 4: Optimisation . . . 20
14.2 Roadmap Table . . . 20

15 Cross-Framework Integration **20**
15.1 Relationship to Other Frameworks . . . 20
15.2 Example Mapping Themes . . . 21

16 Maturity Model **21**
16.1 Suggested Maturity Levels . . . 21
16.1.1 Level 1: Initial . . . 21
16.1.2 Level 2: Repeatable . . . 21
16.1.3 Level 3: Defined . . . 21
16.1.4 Level 4: Managed . . . 21
16.1.5 Level 5: Optimised . . . 22
16.2 Assessment Dimensions . . . 22

17 Practical Templates **22**
17.1 Suggested Appendices . . . 22

18 Customisation Notes **22**

19 References **23**

1 Executive Summary

The European Union Artificial Intelligence Act establishes a harmonised legal framework for artificial intelligence across the Union. It is designed to support trustworthy, human-centric AI while protecting health, safety, and fundamental rights. The regulation applies a risk-based approach and introduces different obligations depending on whether an AI system is prohibited, high-risk, subject to transparency requirements, or outside the main mandatory obligations. It also introduces a distinct governance and compliance framework for general-purpose AI models.

This document provides a practical template for defining the organisation's AI Act governance model, AI risk management approach, control structure, implementation roadmap, and assurance model. It can be used to document how the organisation aligns AI governance, legal compliance, risk management, technical controls, oversight, and assurance into a coherent operating model.

2 Overview

2.1 Purpose

This document provides a practical template for defining, implementing, operating, and assuring compliance with the EU AI Act across the enterprise.

2.2 Objectives

The main objectives of applying the AI Act are to:

- ensure AI systems are lawful, safe, and trustworthy
- protect health, safety, and fundamental rights
- establish clear accountability for providers, deployers, and other operators
- identify and manage AI risks proportionately
- strengthen transparency, human oversight, and technical robustness
- support evidence-based governance, assurance, and regulatory readiness
- integrate AI governance with cybersecurity, privacy, architecture, risk, and compliance practices

2.3 Scope

Describe the scope of AI Act applicability in the organisation.

2.3.1 In scope

- AI systems developed, procured, deployed, or materially modified by the organisation
- general-purpose AI models and related downstream uses where applicable
- high-risk AI systems and their lifecycle controls
- transparency-obligation AI use cases
- prohibited-practice screening and controls
- governance, documentation, monitoring, and incident escalation arrangements
- third-party suppliers, embedded AI components, and model/service dependencies

2.3.2 Out of scope

Document justified exclusions, if any.

2.4 Intended Audience

- Board and executive leadership
- Chief Information Officer
- Chief Information Security Officer
- Chief Data Officer
- Chief Risk Officer
- AI governance and model risk teams
- Legal and compliance teams
- Enterprise architecture teams
- Data science, engineering, and product teams
- Procurement and third-party risk teams
- Internal audit and assurance teams
- PMO / transformation teams

3 Regulatory Foundation

3.1 Background

The AI Act is the European Union's harmonised regulatory framework for artificial intelligence. Its purpose is to improve the functioning of the internal market while promoting the uptake of human-centric and trustworthy AI and ensuring a high level of protection of health, safety, and fundamental rights. :contentReferenceoaicite:1

3.2 Regulatory Objectives

Document how the organisation interprets the regulatory objectives of the AI Act:

- promote trustworthy and human-centric AI
- protect fundamental rights and safety
- create a consistent risk-based compliance framework
- strengthen transparency and accountability
- ensure controls across the AI lifecycle
- support innovation within a governed operating model

3.3 Risk-Based Model

Describe how the organisation addresses the AI Act risk model:

- prohibited AI practices

- high-risk AI systems
- limited-risk / transparency-related AI uses
- minimal-risk AI uses
- general-purpose AI model obligations

The European Commission describes the AI Act as a risk-based framework with distinct levels of regulatory obligation depending on the type and impact of the AI use. :contentReferenceoaicite:2

3.4 Applicability and Entity Context

Document the specific applicability of the AI Act to the organisation, including:

- legal entities and jurisdictions
- provider, deployer, importer, distributor, or authorised representative roles
- internal vs external AI use cases
- product vs internal decision-support usage
- embedded AI in third-party products
- GPAI model use, fine-tuning, or downstream integration
- cross-border deployment footprint

3.4.1 Operator role table

AI Use Case	AI System / Model	Organisational Role	Risk Category	Business Owner	Notes
Example	Example	Provider / Deployer	High-risk / Transparency / Other	Example	Example

4 Governance Model

4.1 Governance Objectives

Define the governance objectives for AI Act compliance:

- establish board-level oversight of AI risk and compliance
- define accountability for AI lifecycle decisions
- align AI adoption with ethics, legal, security, and business requirements
- embed AI governance into architecture, procurement, delivery, and operations

- maintain evidence of compliance and control effectiveness
- support continuous monitoring, incident escalation, remediation, and assurance

4.2 Governance Structure

Describe the governance bodies and their responsibilities.

4.2.1 Example governance bodies

- Board / Risk Committee
- Executive AI Governance Committee
- Model Risk / AI Risk Committee
- Data Governance Council
- Architecture Review Board
- Privacy and Ethics Forum
- Security Steering Committee
- Internal Audit

4.3 Three Lines Model

Describe responsibilities across the three lines.

4.3.1 First line

- ownership of AI use cases, systems, and operational controls
- development, deployment, operation, and monitoring activities
- documentation and evidence production
- issue remediation and operational escalation

4.3.2 Second line

- AI governance oversight
- legal and compliance interpretation
- model risk oversight
- privacy, security, and ethics challenge
- policy and standard setting
- independent monitoring

4.3.3 Third line

- internal audit
- independent assurance
- control effectiveness review

5 Roles and Responsibilities

5.1 Key Roles

Document the main AI Act-related roles.

- Board
- CEO / Executive Management
- Chief Information Officer
- Chief Data Officer
- Chief Information Security Officer
- Chief Risk Officer
- AI Governance Lead
- Model Owner
- Product Owner
- Data Protection Officer
- Legal and Compliance Lead
- Security Architect
- Data Science Lead
- Procurement / Third-Party Risk Manager
- Internal Audit

5.2 RACI Matrix

Use the following model and adapt it.

Activity	Board	Exec	AI Gov Lead	Legal	CISO	CDO	Business Owner	Model Owner	Audit
Approve AI governance policy	A	R	C	C	C	C	I	I	I
Screen prohibited practices	I	A	R	R	C	C	C	C	I
Classify AI systems by risk	I	A	R	C	C	C	R	R	I
Approve high-risk AI controls	I	A	R	C	C	C	R	R	I
Maintain technical documentation	I	I	C	C	C	C	R	R	I
Monitor deployed AI systems	I	A	C	I	C	C	R	R	I

Activity	Board	Exec	AI Gov Lead	Legal	CISO	CDO	Business Owner	Model Owner	Audit
Manage serious incidents / issues	I	A	R	C	C	C	R	R	I
Perform independent assurance	I	I	I	I	I	I	I	I	R/A

6 Policy Framework

6.1 Core Policies

List and describe the main AI Act-related policies.

- AI Governance Policy
- Responsible AI Policy
- AI Risk Classification Standard
- High-Risk AI Lifecycle Standard
- Data Governance and Data Quality Standard
- Human Oversight Standard
- Transparency and User Disclosure Standard
- Model Development and Validation Standard
- Model Monitoring and Incident Management Policy
- Third-Party AI Procurement Policy
- Security and Resilience Policy
- Recordkeeping and Documentation Standard

6.2 Standards and Procedures

Document the standards, procedures, playbooks, and operating guidance supporting compliance.

7 Core Processes

7.1 AI Use Case Intake and Classification

Describe the process for:

- registering AI use cases
- determining whether a system meets the AI system definition
- identifying operator role
- screening for prohibited practices
- determining whether the use is high-risk
- identifying transparency obligations
- identifying GPAI model relevance
- recording the compliance pathway

The Commission published guidance on the AI system definition in February 2025 to support the first phase of application of the AI Act. :contentReferenceoaicite:3

7.2 Prohibited Practices Control

Describe the process for:

- screening proposed use cases against prohibited practices
- legal review and escalation
- design-stage controls
- approval gates
- exception handling where legally relevant
- evidence retention
- periodic revalidation

The first AI Act rules to apply included prohibitions, definitions, and AI literacy from 2 February 2025. :contentReferenceoaicite:4

7.3 High-Risk AI Lifecycle Management

Describe the controls for high-risk AI systems, including:

- risk management
- data and data governance
- technical documentation
- recordkeeping and logs
- transparency and instructions for use

- human oversight
- accuracy, robustness, and cybersecurity
- conformity assessment readiness
- change management
- post-market or post-deployment monitoring where applicable

The AI Act sets out detailed obligations for providers and deployers of high-risk AI systems, including technical documentation, logs, corrective action, and cooperation with authorities. :contentReferenceoaicite:5

7.4 Transparency Management

Describe how the organisation handles AI uses that require transparency measures, such as:

- user disclosure that content is AI-generated or AI-manipulated
- chatbot or interaction disclosures where required
- synthetic media or deepfake disclosure controls
- recordkeeping for transparency notices
- content provenance or watermarking controls where applicable

The AI Act includes transparency obligations for certain AI outputs and interactions, including AI-generated or manipulated content in relevant contexts. :contentReferenceoaicite:6

7.5 General-Purpose AI Model Governance

Describe how the organisation governs GPAI model use or provision, including:

- identification of GPAI model dependencies
- provider vs downstream integrator responsibilities
- technical documentation intake
- acceptable use and restrictions
- model evaluation and safety checks
- systemic-risk escalation where relevant
- contractual and supplier assurance controls

The governance rules and obligations for general-purpose AI became applicable on 2 August 2025. :contentReferenceoaicite:7

7.6 Data Governance and Human Oversight

Describe controls for:

- training, validation, and test data governance
- data relevance, representativeness, and quality checks
- bias and performance review
- assignment of human oversight responsibilities
- reviewer competence
- override and intervention mechanisms
- documentation of oversight decisions

7.7 Incident and Issue Management

Describe the process for:

- detection of AI incidents or failures
- escalation of safety, rights, or compliance issues
- investigation
- corrective action
- supplier escalation
- notification to competent authorities where required
- lessons learned
- remediation tracking

7.8 AI Literacy and Awareness

Describe how the organisation addresses AI literacy obligations through:

- role-based awareness
- operator and reviewer training
- executive briefing
- developer and model owner training
- procurement awareness
- records of completion

The Commission states that AI literacy requirements are part of the rules that have applied since 2 February 2025. :contentReferenceoaicite:8

8 Control Framework

8.1 Control Domains

Organise the AI Act control environment into domains.

8.1.1 Example control domains

- governance and oversight
- AI inventory and classification
- prohibited-practice prevention
- high-risk AI controls
- transparency controls
- GPAI governance
- data governance
- human oversight
- technical robustness and cybersecurity
- supplier and third-party AI management
- incident and issue management
- evidence and assurance

8.2 Sample Control Catalogue

Control ID	Control Name	Objective	Control Owner	Frequency	Evidence
AIA-01	AI inventory maintained	Ensure visibility of AI uses and systems	AI Governance Lead	Monthly	AI register
AIA-02	Prohibited-practice screening completed	Prevent unlawful AI use cases	Legal / AI Governance	At intake / change	Screening records
AIA-03	High-risk assessment documented	Classify and govern regulated systems properly	Model Owner	At intake / change	Classification record

Control ID	Control Name	Objective	Control Owner	Frequency	Evidence
AIA-04	Technical documentation maintained	Support compliance and auditability	Model Owner	Ongoing	Technical file
AIA-05	Human oversight assigned	Ensure accountable intervention capability	Business Owner	Ongoing	RACI / procedures
AIA-06	AI incidents tracked	Support issue escalation and remediation	AI Risk Manager	Ongoing	Incident register

9 Artefacts and Evidence

9.1 Required Artefacts

Document the key AI Act artefacts.

- AI governance policy
- AI inventory / use case register
- operator role register
- prohibited-practice screening records
- AI risk classification register
- high-risk AI assessment records
- technical documentation files
- model cards or equivalent documentation
- data governance and data quality records
- human oversight procedures
- instructions for use
- logging and monitoring records
- transparency notices and disclosure evidence
- incident and issue register
- corrective action tracker
- supplier due diligence records
- GPAI dependency register
- training and AI literacy records
- management information and dashboard packs
- audit reports

9.2 Evidence Model

For each artefact define:

- owner
- purpose
- location
- frequency of update
- retention period
- assurance mechanism

10 Architecture and Technology Implications

10.1 AI Governance by Design

Describe how AI Act requirements are embedded into:

- enterprise architecture
- solution design
- data pipelines
- model development lifecycle
- model serving and deployment patterns
- user interface design
- identity and access control
- logging and monitoring architecture
- cloud and platform engineering
- procurement and third-party integration patterns

10.2 Technology and Model Landscape View

Document the AI-relevant landscape:

- business use cases
- data sources and pipelines
- models and services
- embedded third-party AI components
- decision points and human review points
- monitoring and observability tooling
- security and access architecture
- dependency on external models or providers

10.3 Dependency and Data Flow Mapping

Include or reference:

- AI use case maps
- model lifecycle diagrams
- data lineage diagrams
- third-party dependency maps
- human oversight workflow diagrams
- incident escalation workflows

11 Risk Management

11.1 AI Risk Model

Describe how AI risks are identified, assessed, treated, accepted, escalated, and monitored.

11.2 Example Risk Categories

- prohibited or unlawful use case risk
- misclassification of AI systems
- weak documentation and evidence
- poor data quality or biased data
- inadequate human oversight
- lack of transparency to affected persons or users
- model robustness or cybersecurity weakness
- supplier or GPAI dependency risk
- rights, discrimination, or safety impacts
- poor incident escalation and remediation

11.3 Risk Register Template

Risk ID	Risk Description	Cause	Impact	Likelihood	Inherent Risk	Control Strength	Residual Risk	Owner
AI-01	Example	Example	Example	Medium	High	Medium	Medium	Example

12 Metrics and Reporting

12.1 Key Metrics

Examples of AI Act metrics:

- number of AI use cases registered
- percentage of AI use cases classified
- number of prohibited-practice escalations
- number of high-risk AI systems in scope
- percentage of high-risk systems with complete technical documentation
- percentage of AI systems with assigned human oversight
- number of transparency notices implemented
- number of AI incidents or significant issues
- percentage of third-party AI suppliers assessed
- percentage of relevant staff completing AI literacy training
- number of open audit or compliance findings
- percentage of remediation actions completed on time

12.2 Dashboard Structure

Suggested dashboard views:

- executive AI governance dashboard
- AI inventory and classification dashboard
- high-risk AI compliance dashboard
- incident and issue dashboard
- third-party and GPAI dependency dashboard
- audit and remediation dashboard

13 Audit and Assurance

13.1 Assurance Model

Document the assurance approach across:

- management self-assessment
- control owner attestations
- second-line compliance reviews
- model and documentation reviews
- internal audit

- regulatory readiness reviews

13.2 Testing Themes

- governance and accountability
- AI inventory completeness
- prohibited-practice screening effectiveness
- classification quality
- technical documentation completeness
- human oversight effectiveness
- transparency implementation
- supplier and GPAI governance
- incident handling
- evidence traceability

14 Implementation Roadmap

14.1 Maturity Phases

14.1.1 Phase 1: Foundation

- establish AI governance and executive sponsorship
- define policy framework
- create AI inventory and intake process
- implement prohibited-practice screening
- launch AI literacy awareness

14.1.2 Phase 2: Control Design

- implement classification methodology
- formalise high-risk AI lifecycle controls
- define transparency and human oversight standards
- strengthen documentation and evidence model
- establish supplier and GPAI governance controls

14.1.3 Phase 3: Integration

- integrate AI governance with privacy, security, architecture, and procurement
- embed controls into delivery lifecycle and change governance
- improve monitoring, incident handling, and remediation tracking
- align dashboards and management reporting

14.1.4 Phase 4: Optimisation

- strengthen assurance and independent review
- improve automation of evidence collection
- refine supplier oversight and ongoing monitoring
- mature executive reporting and continuous improvement

14.2 Roadmap Table

Initiative	Description	Owner	Priority	Timeline	Dependency	Status
Example	Example	Example	High	Q1-Q2	Example	Planned

15 Cross-Framework Integration

15.1 Relationship to Other Frameworks

Describe how the AI Act integrates with:

- GDPR
- ISO/IEC 27001
- NIS2
- DORA
- NIST Cybersecurity Framework
- COBIT
- ITIL
- TOGAF
- enterprise risk management
- data governance and model risk management frameworks

15.2 Example Mapping Themes

AI Act Theme	Related Framework	Integration Point
Data governance	GDPR / Data Governance	Data quality, lawful processing, accountability
Robustness and cybersecurity	ISO 27001 / NIST CSF	Security controls and resilience
High-risk governance	COBIT	Governance objectives and decision accountability
Architecture integration	TOGAF	AI design authority and solution governance
Incident management	NIS2 / DORA	Escalation, resilience, and notification discipline

16 Maturity Model

16.1 Suggested Maturity Levels

16.1.1 Level 1: Initial

AI use is fragmented, poorly inventoried, and weakly governed.

16.1.2 Level 2: Repeatable

Basic AI review and approval processes exist but are inconsistently applied.

16.1.3 Level 3: Defined

AI governance, classification, documentation, and oversight processes are documented and broadly implemented.

16.1.4 Level 4: Managed

AI risks, controls, incidents, and compliance obligations are measured, monitored, and regularly reviewed.

16.1.5 Level 5: Optimised

AI governance is integrated into enterprise governance, delivery, architecture, security, and assurance with strong evidence and continuous improvement.

16.2 Assessment Dimensions

- governance
- inventory and classification
- prohibited-practice prevention
- high-risk AI control design
- transparency and disclosure
- data governance
- human oversight
- supplier and GPAI governance
- incident management
- assurance and improvement

17 Practical Templates

17.1 Suggested Appendices

- Appendix A: AI use case intake template
- Appendix B: AI classification template
- Appendix C: Prohibited-practice screening checklist
- Appendix D: High-risk AI control checklist
- Appendix E: Technical documentation template
- Appendix F: AI incident register
- Appendix G: AI Act control catalogue
- Appendix H: AI Act RACI matrix

18 Customisation Notes

This template should be tailored to reflect:

- legal entity structure
- sector and regulatory context
- AI operating model
- internal and external AI use cases

- supplier and GPAI dependency profile
- cloud and technology estate
- maturity level
- assurance expectations
- operating model and budget constraints

19 References

Add authoritative references here, for example:

- Regulation (EU) 2024/1689
- European Commission AI Act overview
- Commission guidance on AI system definition
- Commission guidance on prohibited AI practices
- AI Office / GPAI guidance and materials
- internal AI governance policies
- enterprise risk framework
- security, privacy, and architecture standards